AUTHENTICATION & ACCESS CONTROL REPORT

Lab Name: PortSwigger: Username enumeration via subtly different responses

Objective: To exploit a username enumeration vulnerability where the login page returns subtly different responses for valid vs invalid usernames, then brute-force the password.

---

1. Lab Name

PortSwigger: Username enumeration via subtly different responses

2. Objective

To exploit a username enumeration vulnerability where the login page returns subtly different responses for valid vs invalid usernames, then brute-force the password.

3. Vulnerability/Concept

Username enumeration occurs when an application reveals whether a username exists through:

- Different error messages
- Different response times
- Different response lengths
- Different HTTP status codes

In this lab, the login response differs subtly based on whether the username exists. This allows attackers to first enumerate valid usernames, then brute-force passwords only for valid accounts.

---

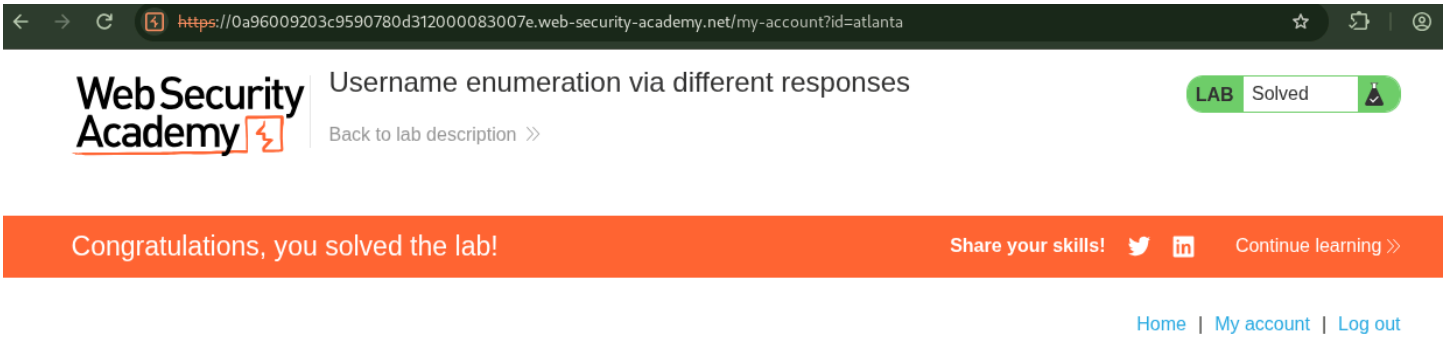
4. Testing Approach

1. Intercepted login request in Burp Suite
2. Sent request to Intruder
3. Marked username field as payload position
4. Loaded username wordlist
5. Started attack
6. Observed response lengths
7. Found `daniel` had different Length (189 vs 3354)
8. Used `daniel` as valid username
9. Repeated process for password
10. Found password: `daniel`
11. Logged in successfully

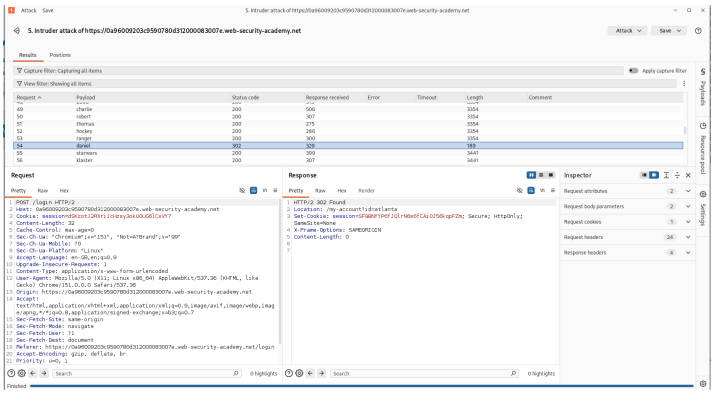
---

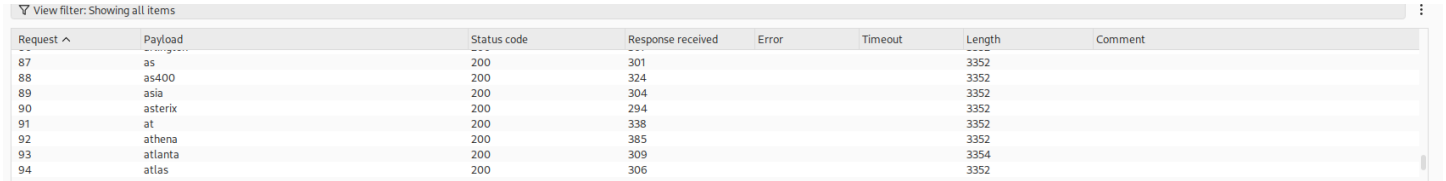
5. Evidence/Screenshots

1. Lab completion - "Solved" banner



2. Burp Intruder results showing different response length

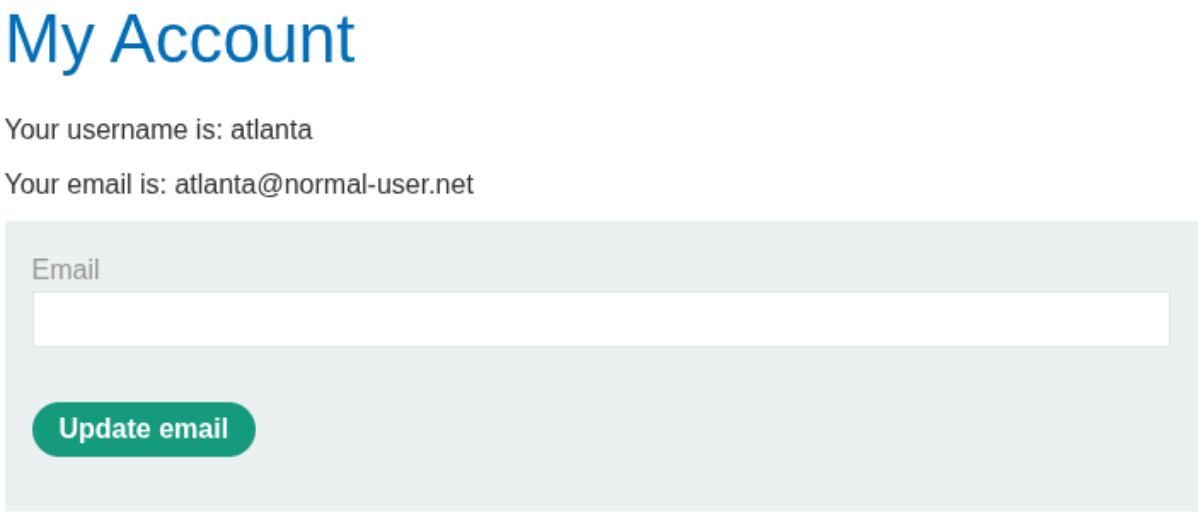




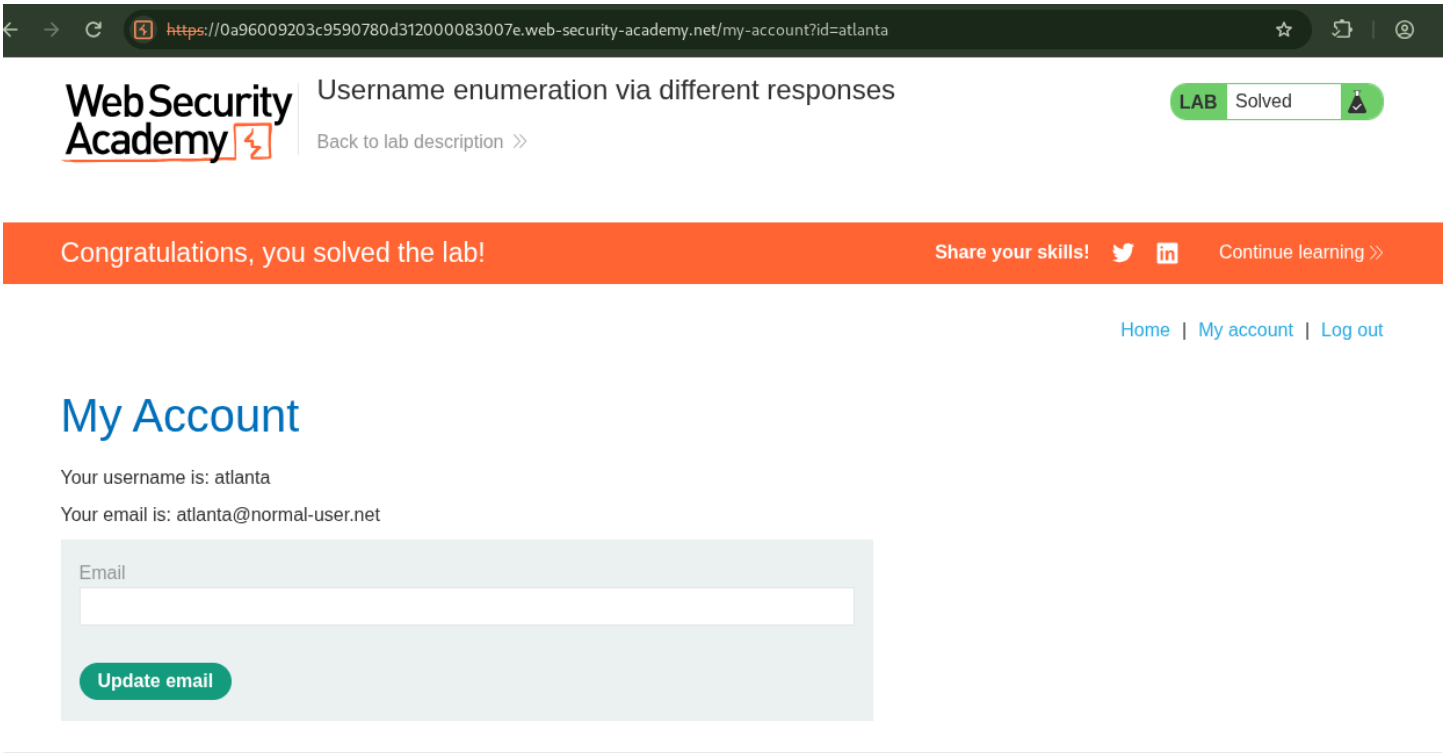
View filter: Showing all items

Request	Payload	Status code	Response received	Error	Timeout	Length	Comment
87	as	200	301			3352	
88	as400	200	324			3352	
89	asia	200	304			3352	
90	asterix	200	294			3352	
91	at	200	338			3352	
92	athena	200	385			3352	
93	atlanta	200	309			3354	
94	atlas	200	306			3352	

3. Successful login / account page



4. Full page evidence



6. Impact

- Attackers can discover valid usernames
- Reduces brute-force search space
- Enables targeted password attacks
- Leads to account takeover
- Information disclosure

7. Remediation

- Use generic error messages ("Invalid username or password")
- Ensure consistent response times
- Ensure consistent response lengths
- Implement rate limiting
- Use CAPTCHA after failed attempts
- Account lockout policies

---

8. What You Learned

- Subtle response differences can leak information
- Burp Intruder is powerful for enumeration
- Response length/status code differences matter
- Username enumeration enables password attacks
- Consistent responses prevent enumeration
